

RAPPORT DE CADRAGE RÉGLEMENTAIRE

Finexa (exemple)

Infrastructure numérique · Finexa SAS · SIREN 000 000 000 · Établi par Consultant du cabinet · À l'attention de Thomas Lefèvre, directeur général délégué · Établi le 30 septembre 2026

MISSION	CAD-2026-014
OBJECTIF	Établir les textes applicables avant l'audit ACPR de 2027 et arbitrer le budget conformité de l'exercice.
PÉRIODE	7 septembre 2026 -> 16 octobre 2026
CONSULTANT	Consultant du cabinet
COMMANDITAIRE	Thomas Lefèvre, directeur général délégué
GROUPE	Indépendant
PÉRIMÈTRE	Établissement de paiement agréé par l'ACPR, 50 salariés, présent en France, en Belgique et en Espagne. Fournit une plateforme de paiement en nuage à des commerçants et édite un SDK d'encaissement intégré dans leurs applications.
INTERLOCUTEURS	Karim Benali (RSSI) · Claire Morel (DPO) · Inès Garnier (Conformité)

Synthèse

5 textes s'appliquent (RGPD, NIS2 (ReCyF), DORA, CRA, AI Act), soit 40 exigences unifiées. Couverture déclarée : 46 % ; 9 exigences sans aucune mesure, 17 partiellement couvertes.

OBLIGATIONS

61

232 exigences élémentaires

EXIGENCES UNIFIÉES

40

dont 36 évaluées

COUVERTURE

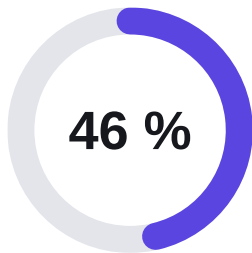
46 %

partiel compté pour moitié

SANCTION MAXIMALE

20 M€

Plafond RGPD



couverture globale

COUVERTURE PAR TEXTE

RGPD		50 %
NIS2 (ReCyF)		44 %
DORA		42 %
CRA		47 %
AI Act		45 %

RÉPARTITION PAR TEXTE

RGPD		36 exig.
NIS2 (ReCyF)		31 exig.
DORA		33 exig.
CRA		15 exig.
AI Act		22 exig.

■ En place ■ Partiel ■ Absent ■ Non évalué

01 Qualification au regard de chaque texte

Chaque verdict est accompagné des conditions d'application examinées. Les réserves signalent ce qui reste à confirmer hors de la plateforme ; les montants sont les plafonds légaux, valorisés sur le chiffre d'affaires déclaré.

RGPD Règlement (UE) 2016/679		Applicable · Responsable de traitement et sous-traitant, délégué obligatoire
FONDEMENT	CONDITION EXAMINÉE	ÉTAT
Article 2	Traitement de données à caractère personnel L'entité déclare traiter des données à caractère personnel : le règlement s'applique matériellement.	Remplie
Article 3, paragraphe 1	Établissement dans l'Union L'entité est établie dans l'Union : le critère territorial est rempli, quel que soit le lieu du traitement.	Remplie
Exposition : 20 M€. 4 % d'un chiffre d'affaires de 10 à 50 M€ représente environ 1,2 M€ ; le plafond forfaitaire est de 20 M€. Le montant le plus élevé est retenu.		
Réserve : Le volet « données » du paquet Digital Omnibus, en négociation depuis novembre 2025, pourrait modifier la définition de la donnée personnelle et le régime du consentement. Aucun texte n'est adopté à ce jour.		

NIS2 (ReCyF) Directive (UE) 2022/2555		Applicable · Entité importante
FONDEMENT	CONDITION EXAMINÉE	ÉTAT
Annexes I et II	Appartenance à un secteur couvert Le secteur « Infrastructure numérique » relève de l'annexe I (secteurs hautement critiques).	Remplie
Article 2, paragraphe 1	Franchissement du seuil de moyenne entreprise L'entité atteint le seuil de moyenne entreprise : 50 personnes, ou chiffre d'affaires et bilan supérieurs à 10 M€.	Remplie
Exposition : 7 M€. 1,4 % d'un chiffre d'affaires de 10 à 50 M€ représente environ 420 k€ ; le plafond forfaitaire est de 7 M€. Le montant le plus élevé est retenu.		
Réserve : La directive n'est pas transposée en France au 24 septembre 2026. Les obligations ne seront exigibles qu'à la publication de la loi résilience et de ses décrets, mais le ReCyF publié par l'ANSSI en fixe déjà le contenu attendu.		
Réserve : L'entité étant une entité financière soumise à DORA, l'article 4 de NIS2 écarte les dispositions de la directive relatives à la gestion des risques et à la notification des incidents, DORA constituant une lex specialis. Le rattachement à l'écosystème NIS2 subsiste.		

DORA Règlement (UE) 2022/2554		Applicable · Entité financière
FONDEMENT	CONDITION EXAMINÉE	ÉTAT
Article 2, paragraphe 1	Appartenance à la liste limitative des entités financières L'entité relève du type « Établissement de paiement », visé à l'article 2. Le règlement s'applique directement et intégralement.	Remplie
Exposition : non chiffré. DORA ne fixe pas de plafond européen harmonisé pour les entités financières : chaque État membre détermine des sanctions effectives, proportionnées et dissuasives. En France, les plafonds sont ceux du code monétaire et financier applicables à la catégorie d'entité concernée. Les autorités peuvent en outre publier les sanctions et engager la responsabilité des personnes physiques dirigeantes.		
Réserve : DORA constitue une lex specialis par rapport à NIS2 (considérant 16). Les dispositions de NIS2 relatives à la gestion des risques et à la notification des incidents ne s'appliquent donc pas en parallèle.		

CRA Règlement (UE) 2024/2847		Applicable · Fabricant, produit par défaut
FONDEMENT	CONDITION EXAMINÉE	ÉTAT
Article 2, paragraphe 1	Mise sur le marché de produits comportant des éléments numériques L'entité intervient en tant que fabricant. Le règlement s'applique aux produits qu'elle met à disposition sur le marché de l'Union.	Remplie
Article 2, paragraphes 2 à 7	Absence de réglementation sectorielle excluante Aucune exclusion sectorielle déclarée.	Remplie
Articles 7, 8 et 32, annexes III et IV	Catégorie du produit le plus exposé La catégorie la plus élevée déclarée est celle de produit par défaut. L'évaluation de la conformité peut être conduite en interne (module A).	Remplie

Exposition : 15 M€. 2,5 % d'un chiffre d'affaires de 10 à 50 M€ représente environ 750 k€ ; le plafond forfaitaire est de 15 M€. Le montant le plus élevé est retenu.

Réserve : Application par paliers : le signalement des vulnérabilités exploitées et des incidents graves est exigible depuis le 11 septembre 2026, y compris pour les produits déjà sur le marché ; les exigences essentielles, le marquage CE et la documentation technique le seront au 11 décembre 2027.

Réserve : En France, l'ANSSI est l'autorité notifiante et la surveillance du marché est pressentie pour l'ANFR ; la désignation formelle reste à confirmer.

AI Act Règlement (UE) 2024/1689		Applicable · Déployeur, risque limité
FONDEMENT	CONDITION EXAMINÉE	ÉTAT
Article 2, paragraphe 1	Fourniture ou utilisation de systèmes d'IA L'entité intervient en tant que déployeur. L'obligation de maîtrise de l'IA (art. 4) s'applique dès l'usage professionnel d'un système d'IA.	Remplie
Article 5	Absence de pratique interdite Aucune pratique interdite déclarée.	Remplie
Article 6 et annexes I et III	Système à haut risque Aucun système à haut risque déclaré.	Non remplie
Article 50	Obligations de transparence Les usages déclarés (interaction, contenus générés, hypertrucages ou reconnaissance des émotions) emportent l'information des personnes, applicable depuis le 2 août 2026.	Remplie

Exposition : 900 k€. 3 % d'un chiffre d'affaires de 10 à 50 M€ représente environ 900 k€ ; le plafond forfaitaire est de 15 M€. Le montant le plus bas est retenu.

Réserve : Un déployeur qui met un système à haut risque sur le marché sous son nom, le modifie substantiellement ou en change la destination devient fournisseur au sens de l'article 25.

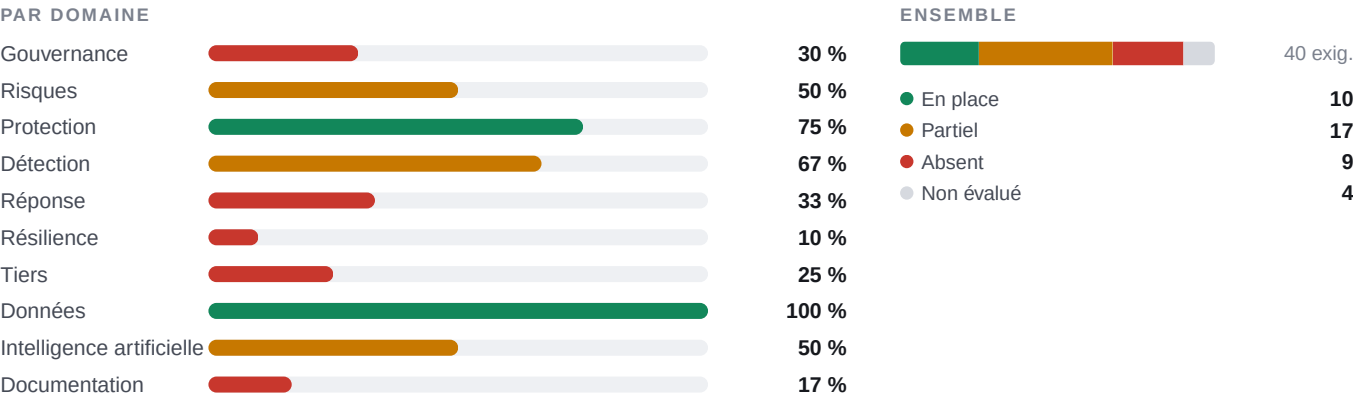
Réserve : En France, les autorités compétentes ne sont pas encore formellement désignées : le schéma gouvernemental confie la coordination à la DGCCRF, avec la CNIL et les autorités sectorielles.

02 Périmètre d'obligations retenu

TEXTE	OBLIGATIONS RETENUES	EXIGENCES ÉLÉMENTAIRES	ÉCARTÉES
RGPD	18	65	3
NIS2 (ReCyF)	7	20	15
DORA	20	89	2
CRA	11	42	1
AI Act	5	16	13
Total	61	232	34

Entité financière : DORA remplace les obligations de gestion des risques et de notification de NIS2 (article 4 de NIS2). Les obligations correspondantes de NIS2 sont comptées comme écartées.

03 État de couverture déclaré



Démarche ISO/IEC 27001 déclarée : partielle. 93 contrôles de l'annexe A renseignés ; 10 exigences unifiées pré-remplies à partir des contrôles mis en œuvre ; 1 exigence obligatoire dont le contrôle correspondant a été exclu de la démarche.

ÉCARTS CONSTATÉS

26 exigences

RANG	EXIGENCE UNIFIÉE	TEXTES	NIVEAU	PORTEUR
1	Responsabilité de l'organe de direction	RGPD · NIS2 (ReCyF) · DORA · AI Act	● Absent	Direction générale
2	Corpus documentaire et politiques	RGPD · NIS2 (ReCyF) · DORA · CRA · AI Act	● Absent	Conformité
3	Notification des incidents à l'autorité	RGPD · NIS2 (ReCyF) · DORA · CRA · AI Act	● Absent	RSSI
4	Sauvegardes et restauration	RGPD · NIS2 (ReCyF) · DORA	● Absent	DSI
5	Registre et cartographie des tiers	RGPD · NIS2 (ReCyF) · DORA	● Absent	Achats
6	Tests, exercices et audits	RGPD · NIS2 (ReCyF) · DORA · CRA · AI Act	● Absent	DSI
7	Lex specialis : DORA prime sur NIS2	DORA · NIS2 (ReCyF)	● Absent	Direction générale
9	Inventaire et classification des systèmes d'IA	AI Act · RGPD	● Absent	DPO
10	Transparence envers les personnes	AI Act · RGPD	● Absent	DPO
12	Fonction dédiée et point de contact	RGPD · NIS2 (ReCyF) · DORA · CRA	● Partiel	Direction générale
13	Formation et sensibilisation	RGPD · NIS2 (ReCyF) · DORA · AI Act	● Partiel	Direction générale
14	Communication aux personnes et aux destinataires	RGPD · NIS2 (ReCyF) · DORA · CRA	● Partiel	RSSI
15	Sécurité physique et environnementale	RGPD · NIS2 (ReCyF) · DORA	● Partiel	à désigner
16	Gestion des vulnérabilités	NIS2 (ReCyF) · DORA · RGPD · CRA	● Partiel	à désigner
17	Analyse d'impact préalable	RGPD · DORA · AI Act	● Partiel	RSSI
18	Analyse de risque et approche par les risques	RGPD · NIS2 (ReCyF) · DORA · CRA · AI Act	● Partiel	RSSI
19	Gestion des identités et des accès	RGPD · NIS2 (ReCyF) · DORA · CRA	● Partiel	à désigner
20	Sécurité par conception, développement et changements	RGPD · NIS2 (ReCyF) · DORA · CRA · AI Act	● Partiel	à désigner
21	Détection et supervision de sécurité	NIS2 (ReCyF) · DORA · RGPD · AI Act	● Partiel	à désigner
22	Processus de gestion des incidents	RGPD · NIS2 (ReCyF) · DORA · CRA · AI Act	● Partiel	RSSI
23	Sécurité de la chaîne d'approvisionnement	NIS2 (ReCyF) · DORA · RGPD · CRA · AI Act	● Partiel	Achats
24	Cartographie des systèmes et inventaire des actifs	NIS2 (ReCyF) · DORA · RGPD · AI Act	● Partiel	à désigner
25	Continuité des activités et reprise	RGPD · NIS2 (ReCyF) · DORA	● Partiel	DSI
26	Encadrement contractuel des tiers	RGPD · NIS2 (ReCyF) · DORA · AI Act	● Partiel	Achats
28	Enregistrement et déclaration d'identité	NIS2 (ReCyF) · DORA	● Partiel	Direction générale

30	Pratiques d'IA interdites	AI Act · RGPD	● Partiel	DPO
----	---------------------------	---------------	-----------	-----

04 Points de friction entre textes

Sur ces sujets, les textes applicables ne se recouvrent pas : ils divergent, ou l'un prime sur l'autre. Les lire texte par texte conduirait à mal calibrer les mesures.

Responsabilité de l'organe de direction GOV-01 · Divergence

Les principaux textes remontent la conformité au niveau de l'organe de direction, mais avec des conséquences juridiques très inégales. Le RGPD impose de démontrer la conformité sans viser les dirigeants personnellement ; NIS2 rend les dirigeants responsables de la violation de l'article 21 et permet de leur interdire d'exercer ; DORA leur confie la responsabilité finale du cadre de gestion du risque TIC.

Règle retenue : NIS2 (ReCyF) prévaut : Formation obligatoire des membres de l'organe de direction et responsabilité personnelle engageable, pouvant aller jusqu'à l'interdiction d'exercer.

Fonction dédiée et point de contact GOV-02 · Divergence

Chaque texte impose une figure de référence, mais leurs statuts sont incompatibles : le délégué à la protection des données doit être indépendant et sans conflit d'intérêts, tandis que le point de contact NIS2 et le responsable DORA sont des fonctions opérationnelles. Fusionner ces rôles dans une seule personne expose à un conflit d'intérêts opposable.

Règle retenue : RGPD prévaut : Indépendance fonctionnelle du délégué, absence de conflit d'intérêts, rattachement au niveau le plus élevé, impossibilité de le sanctionner pour l'exercice de ses missions.

Journalisation et traçabilité DET-01 · Divergence

La journalisation illustre une tension récurrente : les textes cyber poussent à collecter et conserver largement, le RGPD impose de minimiser et de borner la conservation. Les journaux contenant des identifiants et des adresses IP sont des données personnelles.

Règle retenue : DORA prévaut : Conservation suffisante pour permettre l'analyse des causes profondes et la reconstitution prudentielle des incidents, ce qui excède la durée de principe retenue en matière de journaux techniques.

Notification des incidents à l'autorité REP-02 · Divergence

C'est la divergence la plus opérationnelle du dispositif : plusieurs régimes de notification, plusieurs autorités, plusieurs horloges. Un incident touchant une banque et des données personnelles peut appeler une déclaration à l'ACPR, une alerte à l'ANSSI et une notification à la CNIL, avec des délais et des contenus distincts.

Règle retenue : DORA prévaut : La notification initiale DORA est la plus précoce du dispositif, et elle emprunte un modèle harmonisé obligatoire dont l'usage n'est pas laissé à l'appréciation de l'entité.

Tests, exercices et audits RES-04 · Divergence

Tous les textes demandent de vérifier l'efficacité des mesures, mais l'intensité varie fortement : simple évaluation régulière pour le RGPD, audits réservés aux entités essentielles dans le ReCyF, programme complet et tests de pénétration fondés sur la menace tous les trois ans pour DORA.

Règle retenue : DORA prévaut : Test de pénétration fondé sur la menace au moins tous les trois ans, en production réelle, sur un périmètre validé par l'autorité et attesté par elle.

Encadrement contractuel des tiers TIE-01 · Divergence

Le RGPD et DORA imposent tous deux des mentions contractuelles obligatoires, mais elles ne se recouvrent presque pas : l'article 28 du RGPD porte sur le traitement des données, l'article 30 de DORA sur la résilience du service. Un contrat conforme à l'un ne l'est pas à l'autre.

Règle retenue : DORA prévaut : Droits d'accès, d'inspection et d'audit illimités, objectifs de performance quantitatifs, et stratégie de sortie assortie d'une période de transition suffisante.

Pratiques d'IA interdites IA-02 · Divergence

L'article 5 interdit des usages, pas des technologies. Plusieurs de ces interdictions recoupent des traitements que le RGPD encadrerait déjà strictement, comme la catégorisation biométrique fondée sur des données sensibles. L'AI Act les fait basculer dans l'interdiction pure, avec le plafond de sanction le plus élevé des cinq textes couverts.

Règle retenue : AI Act prévaut : Interdiction absolue des pratiques de l'article 5, sanctionnée jusqu'à 35 M€ ou 7 % du chiffre d'affaires mondial.

Lex specialis : DORA prime sur NIS2 HIE-01 · Primauté

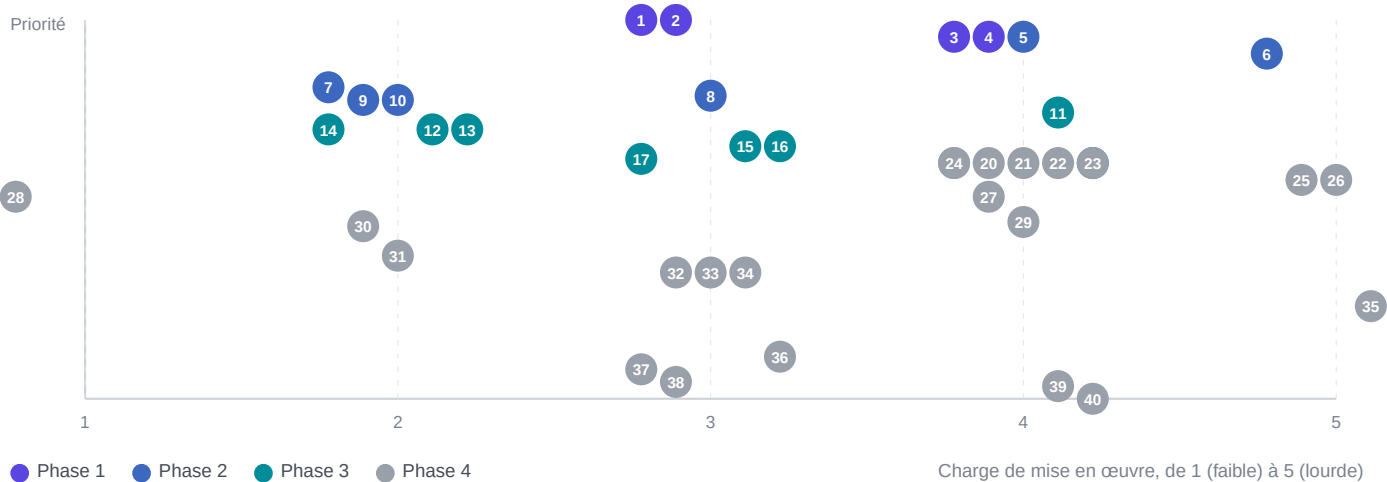
DORA se déclare expressément lex specialis par rapport à NIS2. L'article 4 de NIS2 en tire la conséquence : lorsqu'un acte sectoriel impose des exigences d'effet au moins équivalent, les dispositions correspondantes de NIS2 cessent de s'appliquer. Une entité financière soumise à DORA n'applique donc pas en parallèle le régime de gestion des risques et de notification de NIS2.

Règle retenue : Considérant 16 de DORA : « le présent règlement constitue une lex specialis en ce qui concerne la directive (UE) 2022/2555 ». Article 4 de NIS2 : les dispositions de la directive ne s'appliquent pas lorsque des actes sectoriels imposent des exigences d'effet au moins équivalent.

05 Plan de traitement

L'ordre résulte d'une pondération explicite (exposition juridique 30, écart constaté 30, effet de levier 20, urgence calendaire 10, faible charge 10), corrigée des antériorités techniques. Les horizons sont indicatifs ; seule la séquence engage.

PRIORITÉ ET CHARGE DE CHAQUE EXIGENCE



PHASE 1 0 à 3 mois · 4 exigences

Réduire l'exposition la plus grave et poser les prérequis dont tout le reste dépend.

RANG	EXIGENCE ET ACTION ATTENDUE	TEXTES	AUJOURD'HUI	CHARGE
1	Responsabilité de l'organe de direction Instituer une instance de gouvernance unique (comité sécurité et conformité) qui approuve formellement les politiques, suit les indicateurs et consigne ses décisions. Une seule délibération, correctement rédigée, vaut approbation au titre de chacun de ces textes.	RGPD · NIS2 (ReCyF) · ● Absent DORA · AI Act		3/5
2	Corpus documentaire et politiques Constituer un corpus unique, avec une politique cadre et des politiques thématiques, chacune portant une table de correspondance vers les articles qu'elle satisfait. C'est cette table qui transforme un document interne en preuve de conformité.	RGPD · NIS2 (ReCyF) · ● Absent DORA · CRA · AI Act		3/5
3	Notification des incidents à l'autorité Établir une matrice de notification unique (événement, qualification, autorité, délai, modèle, responsable) et la répéter en exercice. L'horloge la plus courte commande la mobilisation de la cellule de crise, même si les autres délais sont plus longs.	RGPD · NIS2 (ReCyF) · ● Absent DORA · CRA · AI Act		4/5
4	Sauvegardes et restauration Définir une politique de sauvegarde unique alignée sur le niveau DORA : périmètre et fréquence par criticité, isolement physique et logique, tests de restauration périodiques en environnement séparé.	RGPD · NIS2 (ReCyF) · ● Absent DORA		4/5

PHASE 2 3 à 6 mois · 6 exigences

Traiter les exigences à fort effet de levier une fois les fondations en place.

RANG	EXIGENCE ET ACTION ATTENDUE	TEXTES	AUJOURD'HUI	CHARGE
5	Registre et cartographie des tiers Tenir un référentiel fournisseurs unique, dont les attributs sont le sur-ensemble des trois exigences, et générer par extraction le registre d'informations DORA, la section destinataires du registre RGPD et la cartographie NIS2.	RGPD · NIS2 (ReCyF) · ● Absent DORA		4/5
6	Tests, exercices et audits Construire un plan pluriannuel de contrôle unique combinant contrôles internes, audits, tests techniques et exercices, dont la profondeur est calibrée sur le régime le plus exigeant applicable à l'entité.	RGPD · NIS2 (ReCyF) · ● Absent DORA · CRA · AI Act		5/5

7	Lex specialis : DORA prime sur NIS2 Pour une entité financière, appliquer DORA comme régime de référence en matière de gestion du risque TIC et de notification d'incidents. NIS2 continue de produire des effets sur les points non couverts par DORA, et l'entité demeure rattachée à l'écosystème NIS2 (groupe de coopération, CSIRT).	DORA · NIS2 (ReCyF)	● Absent	2/5
8	Maintien en sécurité et fin de vie Tenir un registre unique des produits et composants avec leur date de fin d'assistance (celles que l'entité garantit en tant que fabricant, et celles dont elle dépend en tant qu'utilisatrice) et planifier chaque migration avant l'échéance.	CRA · NIS2 (ReCyF) · DORA	● Non évalué	3/5
9	Inventaire et classification des systèmes d'IA Tenir un inventaire unique des systèmes d'IA, relié au registre des traitements : pour chaque système, finalité, fournisseur, rôle de l'entité, données traitées, niveau de risque motivé et responsable. Revoir la classification à chaque nouveau cas d'usage.	AI Act · RGPD	● Absent	2/5
10	Transparence envers les personnes Rédiger des mentions d'information uniques aux points de contact concernés (agent conversationnel, contenus générés, reconnaissance des émotions) qui couvrent à la fois l'information RGPD et la transparence AI Act, et marquer techniquement les contenus générés.	AI Act · RGPD	● Absent	2/5

PHASE 3

6 à 12 mois · 8 exigences

Consolider et formaliser, en vue d'un contrôle.

RANG	EXIGENCE ET ACTION ATTENDUE	TEXTES	AUJOURD'HUI	CHARGE
11	Registres réglementaires Alimenter les registres depuis un socle commun (inventaire des actifs, référentiel fournisseurs, registre des incidents) plutôt que de les tenir séparément. Le format de sortie diffère ; les données d'entrée sont largement les mêmes.	RGPD · DORA · NIS2 (ReCyF) · AI Act	● Non évalué	4/5
12	Fonction dédiée et point de contact Cartographier les rôles exigés par chaque texte applicable et les attribuer distinctement, en documentant l'absence de conflit d'intérêts pour la fonction de délégué. Une même direction peut les coordonner, mais le délégué ne peut pas être celui qui décide des moyens du traitement.	RGPD · NIS2 (ReCyF) · DORA · CRA	● Partiel	2/5
13	Formation et sensibilisation Bâtir un programme annuel à trois niveaux (organe de direction, personnel, profils sensibles) couvrant protection des données, cybersécurité et résilience, avec émargement et mesure d'assimilation. Un seul programme, trois parcours.	RGPD · NIS2 (ReCyF) · DORA · AI Act	● Partiel	2/5
14	Communication aux personnes et aux destinataires Préparer un jeu de modèles de communication par public et par déclencheur, validés en amont par les directions juridique et communication, afin que la rédaction ne soit pas produite sous la pression de la crise.	RGPD · NIS2 (ReCyF) · DORA · CRA	● Partiel	2/5
15	Sécurité physique et environnementale Traiter la sécurité physique comme un volet à part entière de la politique de sécurité : contrôle des accès aux locaux, détection d'intrusion, surveillance, protection des zones hébergeant des systèmes critiques.	RGPD · NIS2 (ReCyF) · DORA	● Partiel	3/5
16	Gestion des vulnérabilités Organiser un cycle unique de gestion des vulnérabilités avec veille, délais de correction différenciés par criticité, et canal de divulgation coordonnée accessible depuis l'extérieur.	NIS2 (ReCyF) · DORA · RGPD · CRA	● Partiel	3/5
17	Analyse d'impact préalable Intégrer le déclenchement d'une analyse d'impact au jalon de conception des projets, en réutilisant les livrables de l'analyse de risque générale pour la partie menaces et mesures. Seule la partie « atteinte aux droits et libertés » est spécifique au RGPD.	RGPD · DORA · AI Act	● Partiel	3/5
18	Analyse de risque et approche par les risques Conduire une analyse de risque unique, structurée par actif et par fonction, dont les sorties alimentent les différentes lectures : impact sur les personnes, impact sur les services, impact sur les fonctions critiques, impact sur la continuité physique. Une méthode unique (EBIOS Risk Manager s'y prête) et plusieurs restitutions.	RGPD · NIS2 (ReCyF) · DORA · CRA · AI Act	● Partiel	4/5

PHASE 4

Au-delà de 12 mois · 22 exigences

Approfondir, et anticiper les régimes non encore exigibles.

RANG	EXIGENCE ET ACTION ATTENDUE	TEXTES	AUJOURD'HUI	CHARGE
19	Gestion des identités et des accès Déployer un dispositif unique de gestion des identités : moindre privilège, revue périodique des habilitations, authentification multifacteur sur les accès distants et les comptes à privilèges, et séparation stricte des comptes d'administration.	RGPD · NIS2 (ReCyF) · DORA · CRA	● Partiel	4/5
20	Sécurité par conception, développement et changements Insérer dans le cycle de vie projet un jalon de sécurité et de protection des données unique, couvrant exigences de sécurité, minimisation, paramétrage par défaut, revue de code et procédure de changement avec retour arrière.	RGPD · NIS2 (ReCyF) · DORA · CRA · AI Act	● Partiel	4/5
21	Détection et supervision de sécurité Mettre en place une capacité de détection dimensionnée sur la qualification : dispositifs de détection et traitement des alertes pour toutes les entités, supervision continue avec analyse des événements pour les entités essentielles et les entités financières.	NIS2 (ReCyF) · DORA · RGPD · AI Act	● Partiel	4/5
22	Processus de gestion des incidents Construire une procédure unique de gestion des incidents, dont l'étape de qualification applique en parallèle toutes les grilles et déclenche automatiquement les notifications correspondantes. Le processus est commun ; seule la qualification est multiple.	RGPD · NIS2 (ReCyF) · DORA · CRA · AI Act	● Partiel	4/5
23	Sécurité de la chaîne d'approvisionnement Mettre en place une évaluation fournisseur proportionnée à la criticité, exigeant la visibilité sur les sous-traitants ultérieurs, et la réexaminer périodiquement plutôt qu'à la seule contractualisation.	NIS2 (ReCyF) · DORA · RGPD · CRA · AI Act	● Partiel	4/5
24	Cartographie des systèmes et inventaire des actifs Établir et maintenir une cartographie unique (activités et services, systèmes les supportant, actifs matériels et logiciels, dépendances internes et externes, responsable désigné par entrée) et la réviser annuellement.	NIS2 (ReCyF) · DORA · RGPD · AI Act	● Partiel	4/5
25	Continuité des activités et reprise Bâtir un plan de continuité unique, fondé sur les fonctions critiques identifiées, avec des objectifs de temps et de point de rétablissement définis par fonction, testé au minimum annuellement.	RGPD · NIS2 (ReCyF) · DORA	● Partiel	5/5
26	Encadrement contractuel des tiers Construire un corpus de clauses unique, organisé en trois blocs : protection des données (article 28 du RGPD), résilience et service (article 30 de DORA), sécurité de la chaîne (article 21 § 2 d) de NIS2). Le décliner ensuite selon la nature du prestataire.	RGPD · NIS2 (ReCyF) · DORA · AI Act	● Partiel	5/5
27	Gestion de crise Formaliser un dispositif de crise unique (composition, critères de déclenchement, main courante, moyens de communication de secours hors du système d'information principal) et l'exercer selon une périodicité définie.	NIS2 (ReCyF) · DORA	● Non évalué	4/5
28	Enregistrement et déclaration d'identité Constituer une fiche d'identité réglementaire unique (raison sociale, établissements, plages d'adresses IP, secteurs, États membres desservis, contacts) et la maintenir comme source unique pour toutes les déclarations. Fixer une alerte à deux semaines sur toute modification.	NIS2 (ReCyF) · DORA	● Partiel	1/5
29	Concentration et stratégie de sortie Documenter, pour chaque prestataire soutenant une fonction critique, une analyse de substituabilité et une stratégie de sortie opérationnelle, et non une simple clause de réversibilité.	DORA · RGPD	● Non évalué	4/5
30	Pratiques d'IA interdites Soumettre chaque projet d'IA à une revue préalable au regard de l'article 5 et des lignes directrices de la Commission, consignée dans l'inventaire. Traiter tout doute comme un blocage jusqu'à décision motivée.	AI Act · RGPD	● Partiel	2/5
31	Localisation et souveraineté Documenter les choix de localisation et leurs justifications, et anticiper les exigences de présence dans l'Union pesant sur les prestataires critiques, sans confondre obligation juridique et recommandation de souveraineté.	DORA · RGPD · NIS2 (ReCyF)	● En place	2/5

32	Chiffrement et cryptographie Rédiger une politique cryptographique unique définissant algorithmes, longueurs de clés, cas d'usage et gestion du cycle de vie, puis l'appliquer au repos et en transit. Cette politique sert simultanément de mesure article 32 et d'exonération potentielle de l'article 34.	RGPD · NIS2 (ReCyF) · DORA · CRA	● En place	3/5
33	Journalisation et traçabilité Définir une politique de journalisation unique fixant, par catégorie de journal, ce qui est collecté, pourquoi, pendant combien de temps et qui y accède, puis inscrire cette politique au registre des traitements. Le besoin de détection fixe le plancher, la minimisation fixe le plafond.	RGPD · NIS2 (ReCyF) · DORA · AI Act	● En place	3/5
34	Licéité, finalité et minimisation Traiter les dispositifs de sécurité et de résilience comme des traitements de données à part entière : les inscrire au registre, leur attribuer une base juridique et borner leur conservation. C'est le point où une démarche cyber mal conduite crée un risque RGPD.	RGPD · NIS2 (ReCyF) · CRA · AI Act	● En place	3/5
35	Mesures techniques et organisationnelles de sécurité Établir une politique de sécurité des systèmes d'information unique, dont l'architecture épouse les dix mesures de l'article 21 § 2 de NIS2 et les chapitres du règlement délégué 2024/1774. Cette structure couvre par construction l'article 32 du RGPD, qui est moins exigeant.	RGPD · NIS2 (ReCyF) · DORA · CRA · AI Act	● En place	5/5
36	Sécurité des ressources humaines Formaliser les procédures d'arrivée, de mobilité et de départ avec restitution systématique des accès, identifier les fonctions sensibles, et encadrer toute vérification d'antécédents par une base juridique et une information des personnes conformes au RGPD.	RGPD · NIS2 (ReCyF)	● En place	3/5
37	Contrôle humain des décisions assistées par IA Désigner, former et habiller des personnes chargées du contrôle humain des systèmes à haut risque, capables d'ignorer ou d'interrompre le système, et documenter la procédure d'intervention humaine ouverte aux personnes concernées.	AI Act · RGPD	● En place	3/5
38	Droits des personnes Vérifier, pour chaque dispositif technique de sécurité et de résilience, qu'il ne fait pas obstacle à l'exercice des droits, en particulier l'effacement dans les sauvegardes et la rectification dans les journaux.	RGPD · DORA	● En place	3/5
39	Qualité et gouvernance des données d'entraînement Documenter chaque jeu de données d'entraînement (origine, base légale, préparation, analyse des biais) et vérifier la compatibilité de la réutilisation avec la finalité initiale. Publier le résumé des données d'entraînement pour les modèles à usage général.	AI Act · RGPD	● En place	4/5
40	Transferts internationaux Tenir une cartographie unique des localisations de données et de traitement, incluant les accès distants depuis des pays tiers, et en dériver le fondement de transfert RGPD et la mention contractuelle DORA.	RGPD · DORA	● En place	4/5

06 Préparation au signalement

TEXTE	AUTORITÉ	ÉTAPES ET DÉLAIS
RGPD	CNIL	Notification 72 h
NIS2 (ReCyF)	Notifié au titre de DORA	Article 4 de NIS2 : DORA prime pour une entité financière.
DORA	ACPR	Notification initiale 4 h* · Rapport intermédiaire 72 h · Rapport final 1 mois
CRA	ENISA, plateforme unique	Alerte précoce 24 h · Notification 72 h · Rapport final 14 jours / 1 mois
AI Act	Autorité de surveillance du marché (IA)	Infrastructure critique, grande ampleur 2 jours · Décès 10 jours · Autre incident grave 15 jours

* DORA : 4 h après la classification comme incident majeur, et au plus tard 24 h après la prise de connaissance (règlement délégué 2025/301).

ÉTAT DE PRÉPARATION

- Autorités compétentes identifiées
- Responsable sécurité désigné
- Appui technique à la réponse identifié
- Délégué à la protection des données joignable
- Décideur de direction désigné
- Critères de classification DORA connus

CHAÎNE D'ESCALADE

- 1. RSSI** : Karim Benali, Responsable de la sécurité des systèmes d'information
- 2. Réponse** : Astreinte 24/7, Prestataire de réponse aux incidents qualifié PRIS, contrat d'intervention
- 3. DPO** : Claire Morel, Déléguée à la protection des données
- 4. Direction** : Thomas Lefèvre, Directeur général délégué
- 5. Juridique** : Inès Garnier, Responsable juridique et conformité

07 Échéancier

DATE	TEXTE	JALON
7 octobre 2026	NIS2 (ReCyF)	Examen du projet de loi résilience à l'Assemblée nationale La conférence des présidents du 22 septembre 2026 a inscrit le texte transposant NIS2 à l'ordre du jour de la séance publique à partir du 7 octobre. C'est le premier signal concret d'un calendrier de mise en conformité exigible en France.
2 décembre 2026	AI Act	Nouvelle interdiction et fin du délai de marquage Interdiction des systèmes générant des contenus pédopornographiques ou intimes non consentis, et fin du délai accordé aux systèmes déjà sur le marché pour marquer les contenus qu'ils génèrent.
31 décembre 2026	Transverse	Promulgation attendue de la loi résilience Le projet de loi relatif à la résilience des infrastructures critiques et au renforcement de la cybersécurité transpose NIS2, la directive sur la résilience des entités critiques (CER) et la directive d'accompagnement de DORA. Après l'examen en séance publique prévu à partir du 7 octobre, suivront la navette, les décrets d'application et le ReCyF définitif. Date indicative.
17 avril 2027	NIS2 (ReCyF)	Premier réexamen biennal des listes nationales Les États membres réexaminent et mettent à jour la liste des entités essentielles et importantes, au moins tous les deux ans.
11 décembre 2027	CRA	Application intégrale du CRA Exigences essentielles, évaluation de la conformité, marquage CE et obligations des importateurs et distributeurs deviennent exigibles. Un produit non conforme ne peut plus être mis sur le marché de l'Union.

CHARGES RÉCURRENTES

TEXTE	OBLIGATION	FRÉQUENCE
DORA	Remise du registre d'informations	Annuelle
DORA	Tests des systèmes supportant des fonctions critiques	Annuelle
DORA	Test de pénétration fondé sur la menace	Triennale
DORA	Réexamen du cadre de gestion du risque TIC	Annuelle, et après chaque incident majeur
NIS2 (ReCyF)	Revue de la politique de sécurité et de la liste des systèmes	Annuelle
NIS2 (ReCyF)	Revue des comptes, des droits d'accès et des règles de filtrage	Annuelle
NIS2 (ReCyF)	Test des sauvegardes et des restaurations	Annuelle
NIS2 (ReCyF)	Réexamen de l'analyse de risques	Triennale, et en cas d'incident
NIS2 (ReCyF)	Programme d'entraînement et d'exercices	Programme triennal
RGPD	Mise à jour du registre des traitements	Continue
CRA	Suivi des périodes d'assistance	Continue
AI Act	Revue de l'inventaire et de la classification des systèmes d'IA	À chaque nouveau cas d'usage
AI Act	Conservation des journaux des systèmes à haut risque	Continue

08 Journal d'entretien

Points relevés pendant le cadrage. Les vérifications et preuves listées restent ouvertes à la date du rapport.

POINTS À VÉRIFIER		1
OBJET	NOTE	
Type d'entité financière	Confirmer que l'agrément ACPR ne couvre pas aussi l'émission de monnaie électronique : cela changerait le type d'entité financière.	
PREUVES DEMANDÉES		1
OBJET	NOTE	
Registre et cartographie des tiers	Obtenir le registre des prestataires TIC tenu par les Achats (format et date de dernière mise à jour).	
HYPOTHÈSES RETENUES		1
OBJET	NOTE	
Produits comportant des éléments numériques	Le SDK d'encaissement est distribué gratuitement mais intégré à une offre payante : retenu comme mis sur le marché au sens du CRA.	
DÉCISIONS PRISES		1
OBJET	NOTE	
Fonction dédiée et point de contact	Le DPO et le RSSI restent deux fonctions distinctes ; le RSSI devient point de contact DORA.	

09 Méthode, réserves et sources

Nature du document : un livrable de cadrage. Il établit un périmètre probable et un ordre de traitement ; il ne constitue ni un audit de conformité, ni un avis juridique. Les conclusions reposent sur les éléments déclarés, dont l'exactitude n'est pas vérifiée.

Décisions réservées aux autorités compétentes : la désignation comme entité critique (article 3 § 1 f de NIS2), l'identification pour les tests de pénétration fondés sur la menace (DORA) et l'inscription sur la liste nationale des entités essentielles et importantes.

État du droit arrêté au 24 septembre 2026 : NIS2 n'est pas transposée en France ; ses exigences sont détaillées par le ReCyF, document de travail de l'ANSSI. Le CRA impose la déclaration des vulnérabilités activement exploitées depuis le 11 septembre 2026 et s'applique pleinement le 11 décembre 2027. L'AI Act s'applique par paliers ; l'Omnibus IA a reporté les systèmes à haut risque au 2 décembre 2027 (annexe III) et au 2 août 2028 (annexe I).

- SOURCES
- Règlement (UE) 2016/679 : RGPD
 - Directive (UE) 2022/2555 : NIS2 (ReCyF)
 - Règlement (UE) 2022/2554 : DORA
 - Règlement (UE) 2024/2847 : CRA
 - Règlement (UE) 2024/1689 : AI Act
 - Règlement délégué (UE) 2025/301 : notification des incidents majeurs liés aux TIC
 - Règlement (UE) 2026/1744 : Omnibus numérique sur l'IA
 - Référentiel Cyber France (ReCyF) v2.5 : ANSSI, 17 mars 2026